

TEE 锚定准入与信任流驱动的边缘可信联邦学习

TTFL: Trust-Flow-Driven Trusted Federated Learning for Edge Computing

匿名作者

摘要

联邦学习 (FL) 通过避免原始数据迁移来支持边缘智能协同训练, 但开放式参与也引入两类不确定性: 服务器既要判断客户端是否执行了可接受的训练过程, 还要判断其更新在 Non-IID 数据下是否有效, 或是否携带投毒目标。静态 TEE 准入无法回答后一个问题, 而单一更新质量阈值又可能移除合法长尾客户端。本文提出 Trust Flow 框架, 在聚合前始终区分执行可信度、当轮更新内容、长期效用和短期风险四类证据。TEE 锚定的可信管理与证明代理 (TMAA) 提供准入证据; 显式 Kalman 更新以及双流 Beta/EMA 状态模型处理冷启动和跨轮记忆; 按层规则执行风险相关裁剪和保留客户端的按数据量重归一化。实验在两个 Intel/AMD TEE 硬件配置上使用 Flower/PyTorch 和 CIFAR-10, 包含每个平台 5 个随机种子、20 个准入客户端、6 类攻击行为和 30% 恶意客户端。目标攻击 ASR 对三类目标攻击取宏平均, 无目标攻击则通过干净准确率、损失和状态转移指标评估。在给定协议下, Trust Flow 达到 92.31% 的干净准确率、10.21% 的目标攻击 ASR, 测试运行中没有出现永久误封。

关键词: 联邦学习; 边缘计算; 可信执行环境; 风险建模; 分层聚合; 后门防御

1 引言

联邦学习通过参数交换训练全局模型, 并将数据保留在边缘设备本地 [1, 2]。这一范式适合边缘智能场景, 但当客户端身份、执行完整性和更新语义无法完全可信时, 聚合阶段会变得脆弱。实际边缘网络还同时存在设备异构和强偏斜数据分布, 因此鲁棒聚合必须区分恶意偏移和合法长尾更新。在复合攻击下, 这一区分更加困难, 因为攻击者可能提交投毒参数、注入定向后门, 或利用跨轮伪装降低可见异常。

已有工作从不同角度处理这一问题。Krum 和 Trimmed Mean 等几何或统计防御会剔除离群更新 [3, 4]。FLTrust 和 FoolsGold 利用干净参考或时序相似性 [5, 6]; RaSA 与 FLDetector 则面向边缘辅助聚合和模型投毒检测 [7, 8]。面向后门的防御进一步考察深层行为、裁剪加噪或净化机制 [9, 10, 12]; 相关工作也考虑联邦后门检测、定向合谋和隐私保护投毒防御 [11, 13, 14]。这些机制仍面临两类反复出现的张力: 静态软件检查不能保证本地执行确实真实; 过强过滤又容易将 Non-IID 长尾更新误判为攻击。TEE 辅助联邦系统为训练完整性和 SGX 式分布式学习提供硬件信任根 [16, 18], 近期工作进一步研究隐私保护 FL、攻击缓解和恶意参与者下的可信训练 [15, 17, 19]。但客户端准入之后, TEE 本身并不能判断真实训练产生的模型更新是否在语义上安全。

本文提出 *Trust Flow*, 一种面向边缘 FL 的系统级可信聚合决策框架。本文的贡献是明确既有机制之间的执行时序与接口, 而不是提出新的密码学原语或新的 Byzantine 估计器: 先准入执行可信度, 再审查当前更新内容, 随后更新时序证据, 最后分配网络层参与权限。TMAA 提供执行侧证据, 服务器侧信任流将这些证据与更新探针转换为跨轮状态。具体贡献如下:

1. 给出具有明确初始化的准入状态, 将 TEE 式证明、运行时熵和带协方差的 Kalman 递推结合起来, 并规定无历史客户端的保守首轮策略。
2. 建立双流状态模型, 使用显式 Beta 更新描述历史效用, 并使用最强当轮风险探针的 EMA 描述短期风险, 从而避免将良性分布漂移和攻击突发压缩为同一分数。
3. 给出保留原始数据量权重的按层聚合规则, 使用风险相关阈值和裁剪, 并仅对幸存权重重新归一化。
4. 在受控的 Non-IID CIFAR-10 攻击协议下进行双平台评估, 并报告消融结果与超出假设范围的边界压力测试。

2 背景与相关工作

边缘计算中的联邦学习。标准 FL 工作流中, 客户端完成本地训练并向服务器提交参数更新, 服务器聚合后再分发全局模型。该流程保留了数据本地性, 却使服务器高度依赖上传更新的真实性和质量。边缘计算进一步增

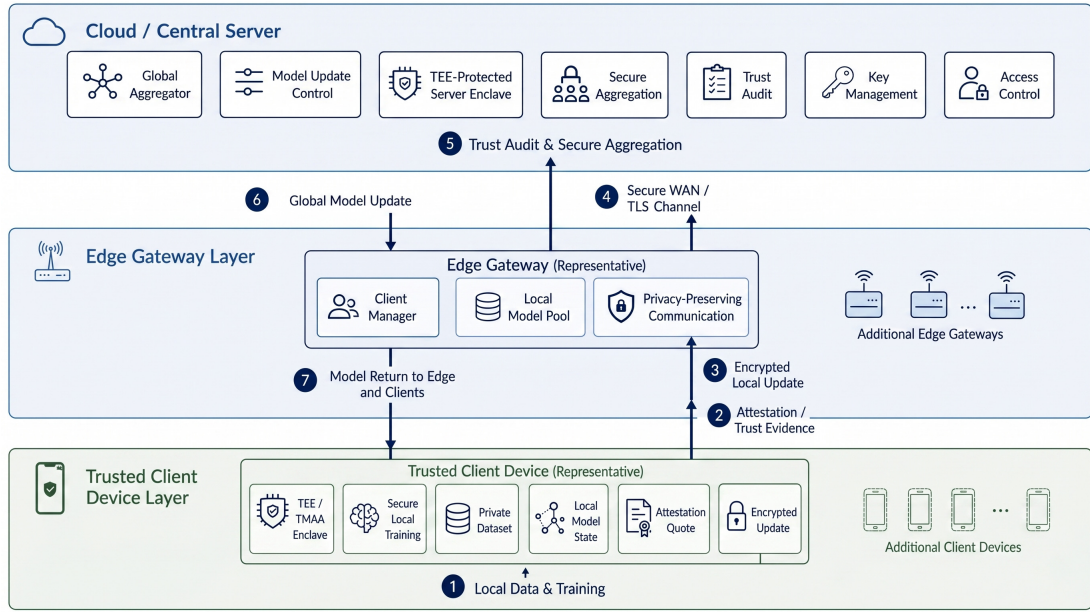


图 1: TEE 锚定的端-边-云协同架构。

加了复杂度,因为客户端的算力、通信稳定性和数据分布均存在差异。更开放、分层的系统也会扩大客户端准入、本地执行和更新聚合周围的攻击面。

投毒与后门攻击。FL 中的攻击主要包括无目标投毒和目标后门。符号翻转、梯度缩放等无目标投毒旨在破坏收敛;标签翻转、触发器后门、干净标签投毒和语义后门则试图保持主任务行为,同时植入定向误分类。后门攻击尤其棘手,因为恶意更新可在方向上接近正常更新,却改变隐藏特征 [20, 21]。在多轮训练中,攻击者还可能先正常行为以积累信任,再注入低幅度或间歇式恶意更新。

主动防御及其局限。鲁棒聚合通常依赖几何距离、坐标级统计、干净锚点、时序相似性或自适应聚合。Krum 与 Trimmed Mean 拒绝或抑制离群更新 [3, 4]; FLTrust 使用服务器端干净参考方向 [5]; FoolsGold 和 FLDetector 利用历史或客户端行为识别恶意参与 [6, 8]; RaSA 在边缘辅助场景下调整安全聚合 [7]。后门防御方面,DeepSight 与 FLAME 检查隐藏行为或更新簇 [9, 10]; CrowdGuard 与 RoseAgg 处理联邦后门检测和定向合谋 [11, 13]; FLPurifier 与 ShieldFL 则从净化或隐私保护防御角度缓解投毒 [12, 14]。但这些防御对强 Non-IID 分布仍较敏感:阈值严格会增加良性误杀,阈值宽松则会放过隐蔽攻击。

TEE 辅助可信训练。Intel SGX 和 ARM TrustZone 等可信执行环境可提供隔离执行与受保护密钥材料。已有研究展示了 TEE 在训练完整性和 SGX 分布式学习中的价值 [16, 18],也将其用于鲁棒隐私保护 FL 和攻击缓解 [15, 17],以及恶意参与者下的可信模型训练 [19]。不过,TEE 准入不能单独判断一个真实训练过程生成的模型更新是否语义安全。因此,Trust Flow 将硬件根准入与跨轮风险建模、分层鲁棒聚合结合起来。

3 系统模型与威胁假设

系统包含中心服务器 $\mathcal{S}$ 与 K 个边缘客户端 $\mathcal{C} = \{c_1, \dots, c_K\}$ 。第 t 轮中,通过准入的客户端接收 $W^{(t-1)}$,完成本地训练后上传 $\Delta W_k^{(t)}$,服务器更新 $W^{(t)} = W^{(t-1)} + \text{Agg}(\{\Delta W_k^{(t)}\})$ 。全局目标为

$$\min_W \mathcal{L}(W) = \sum_{k=1}^K p_k \mathcal{L}_k(W), \quad p_k = |\mathcal{D}_k| / \sum_j |\mathcal{D}_j|. \quad (1)$$

边缘场景遵循端-边-云 workflow: 客户端侧完成本地训练并生成与证明绑定的信任报告,服务器侧审查更新、演化信任状态并执行鲁棒加权聚合。本文不使用 secure aggregation 一词表示该系统能力,因为服务器必须检查单个客户端的证据;密码学隐私保护聚合不在本文范围内。

威胁模型。服务器遵循聚合协议,但属于诚实且好奇的观察者;它可以看到单个更新和审查统计量,但不能修改本文规定的状态转移规则。已准入客户端可以控制本地标签、样本或优化目标,并实施标签翻转、触发器后门、干净标签投毒、语义后门、符号翻转或梯度缩放。信任边界被明确限定为: Intel 和 AMD TEE 保护证明关

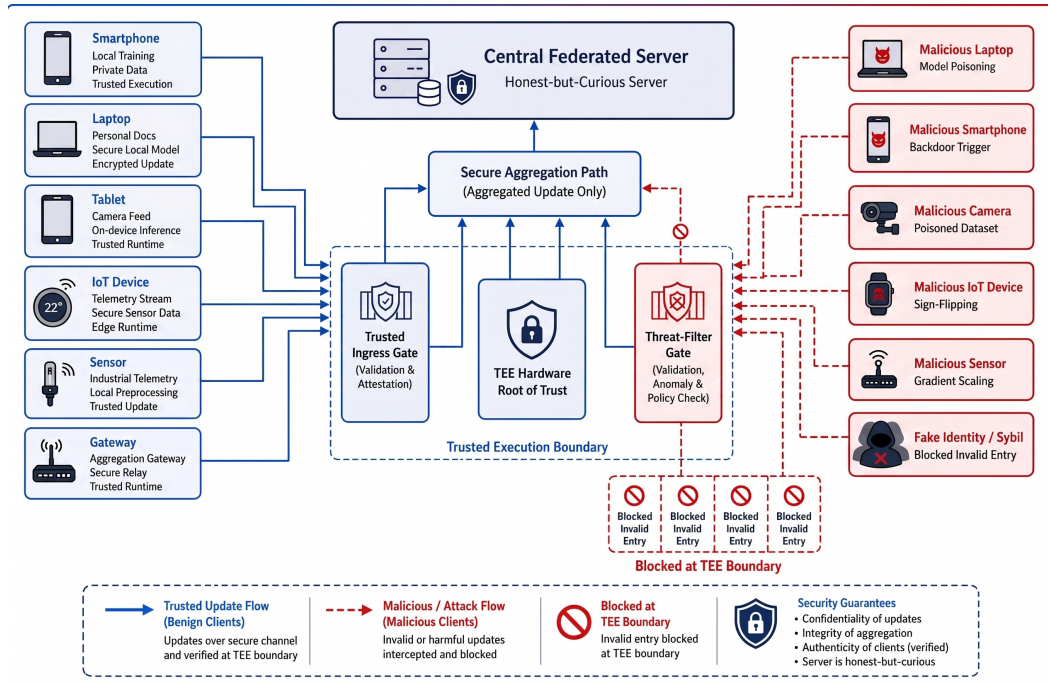


图 2: 复合投毒与渗透威胁模型。

键代码、设备密钥、报告完整性、报告新鲜度以及可信监测路径，使其免受受攻陷宿主操作系统的篡改，但不认证数据标签、优化目标或语义意图。因此，攻击者可以在一个经过有效测量的训练流程内部生成带签名的投毒更新；被排除的仅是证明完成后在受保护路径之外对更新的篡改。如果报告或更新绑定检查失败，服务器拒绝该更新，而不将其视为 TEE 已经成功防御。物理探测和高级微架构侧信道也不在威胁模型内。分析假设恶意准入客户端少于 50%；50% 实验是超出假设范围的压力测试，不构成 Byzantine 阈值或理论保证。服务器持有的 clean proxy set 是一个显式的可选参考假设；对于无法提供该数据的部署，本文定义了可信对客户回退分支，但所有主结果都不声称具备无参考集性能。

设计目标。 Trust Flow 旨在在给定攻击下保持收敛，限制长尾客户端的永久误封，并按系统边界报告开销：附加 TrustReport 约为 15 KB，服务器聚合与审查时间由 2.10 s 增至 4.85 s，辅助安全路径实测为每个准入客户端每轮约 11 ms，覆盖 enclave 切换、内存压力和密码学聚合路径的开销；设备侧 TEE Quote 生成、签名和轻量监测另行实测为每个准入客户端每轮约 12–15 ms。完整端到端通信延迟和厂商特定证明延迟不在本文报告的测量范围内。该框架把召回率与误报率之间的冲突转化为状态分离问题：准入、内容、历史和风险在按层聚合前始终保持为不同信号。

4 Trust-Flow 框架

Trust Flow 将每一轮 FL 划分为四个相互连接的阶段：准入与运行时信任评估、基于参考的内容审查、双流状态演化以及风险门控分层聚合。图 3 展示了完整防御闭环。

从更高层看，该框架是一条信任状态转移管线。第一阶段输出 *TrustScore*，刻画客户端是否具有可信参与基础；第二阶段输出 *ContentScore*，衡量当前更新是否与干净参考和群体方向一致；第三阶段将这些信号沉淀为 *HistPerf* 与 *RiskEMA*，分离长期贡献和短时异常；第四阶段将状态融合为 *RawScore* 并执行差异化分层聚合。这一设计避免把某一轮低分直接视为恶意证据，这对强 Non-IID 数据下的长尾客户端尤其重要。

从操作流程看，每一轮都遵循相同的决策路径。服务器先移除未通过准入证明的客户端，因为这些更新无法绑定到受保护执行路径；随后对剩余更新计算其相对于干净参考和可信群体的质量，但该分数仍只是临时证据。临时证据会被沉淀到慢速效用状态和快速风险状态中，最后才转化为按层聚合权限。这样的顺序是有意设计的：前置阶段回答证据是否可信，中间阶段判断当前更新是有用还是有风险，最终阶段再决定该更新能在哪些网络层参与贡献。因此，框架避免在每轮开始时设置单一硬门槛，从而降低强 Non-IID 下的脆弱性，同时在风险证据持续存在时仍能执行硬隔离。

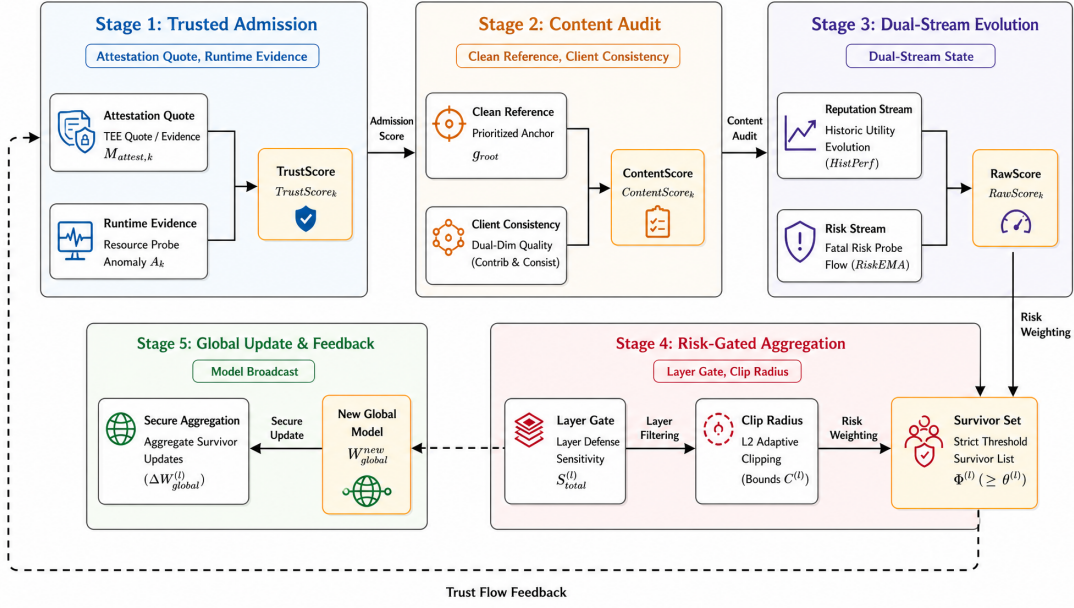


图 3: 四阶段信任流防御闭环概览。

4.1 准入与内容审查

每个准入客户端都必须通过 TEE 式准入检查。令 $M_{attest,k} \in \{0, 1\}$ 表示证明报告、随机数新鲜度以及轮次和更新摘要绑定是否有效。初始化期间, 客户端调用设备唯一密钥并生成包含代码度量、运行配置、轮次随机数、更新摘要和单调新鲜计数器的远程证明 quote。只有通过该检查的客户端才获得通信权限。本地训练期间, 可信管理代理监测行为序列 $\mathcal{X}_k^{(t)} = \{\Delta grad, \Delta loss, instr_dist\}$ 。将标准化特征直方图拼接后, 令 $h_k^{(t)} = H(\mathcal{X}_k^{(t)})/H_{max} \in [0, 1]$, 并定义

$$R_k^{(t)} = \exp(\lambda h_k^{(t)}), \quad Z_k^{(t)} = \text{clip}(w_a M_{attest,k} + (1 - w_a)(1 - h_k^{(t)}), 0, 1), \quad (2)$$

其中 $w_a = 0.7$ 、 $\lambda = 1.0$ 。高熵只表示证据不确定性增加, 并不直接等价于恶意标签。

标量 Kalman 递推为

$$T_k^{-(t)} = T_k^{-(t-1)}, \quad P_k^{-(t)} = P_k^{-(t-1)} + Q, \quad (3)$$

$$\begin{aligned} K_k^{(t)} &= \frac{P_k^{-(t)}}{P_k^{-(t)} + R_k^{(t)}}, \\ T_k^{(t)} &= T_k^{-(t)} + K_k^{(t)}(Z_k^{(t)} - T_k^{-(t)}), \\ P_k^{(t)} &= (1 - K_k^{(t)})P_k^{-(t)}. \end{aligned} \quad (4)$$

其中 $Q = 0.01$ 为固定过程噪声方差。新准入客户端初始化为 $T_k^{(0)} = 1$ 、 $P_k^{(0)} = 0.25$ 和 $RiskEMA_k^{(0)} = 0$, 其准入权限为

$$TrustScore_k^{(t)} = M_{attest,k} \text{clip}\left(\frac{T_k^{(t)}}{1 + P_k^{(t)}}, 0, 1\right). \quad (5)$$

高熵会降低 Kalman 增益, 防止不确定观测突然改写跨轮信任。有效证明后的新客户端从 NORMAL 状态开始, 首轮证据只能降低当前更新权限, 不能触发不可逆黑名单。

随后, 服务器构造干净指导方向。若存在小型干净验证梯度, 则 $g_{root} = g_{root_clean}$; 否则, 使用高信任且上一轮风险较低的客户端, 并以 $\omega_k^{ref} = TrustScore_k(1 - RiskEMA_k^{prev})^2$ 作为参考权重。实验中服务器持有来自 CIFAR-10 测试集的 500 个均衡 proxy 样本 (每类 50 个), 该集合不参与客户端训练, 并向所有依赖参考集的基线提供, 同时用于干净损失和激活探针。该退化参考在边缘部署中很重要: 服务器侧数据集可能很小甚至不存在, 此时参考方向应保持保守, 但不能被近期可疑客户端主导。对每个客户端更新, 内容质量由参考一致性和群体一

致性共同构成：

$$S_{contrib,k} = \max(0, \alpha_1 + \alpha_2 \cos(\Delta W_k, g_{root})), \quad (6)$$

$$S_{consist,k} = \frac{\sum_{j \neq k} TrustScore_j \max(0, \alpha_1 + \alpha_2 \cos(\Delta W_k, \Delta W_j))}{\sum_{j \neq k} TrustScore_j + \varepsilon}, \quad (7)$$

$$ContentScore_k = \frac{(1 + \beta_{fusion}^2) S_{consist,k} S_{contrib,k}}{\beta_{fusion}^2 S_{consist,k} + S_{contrib,k} + \varepsilon}. \quad (8)$$

其中 $\beta_{fusion} > 1$ 会提高干净方向的影响，有助于抵抗合谋漂移。这里采用调和式融合并非只为数值平滑，而是要求客户端同时在干净参考和可信群体两个方向上都具有合理性。仅有较高群体一致性不足以抵抗合谋，只有较高参考一致性又可能过度惩罚合法 Non-IID 更新。

4.2 双流状态演化

单一信誉分会混淆由数据偏斜导致的低效用和由攻击导致的高风险。Trust Flow 因此将客户端状态分为历史效用流和瞬时风险流。令 $q_k^{(t)} = \text{clip}(ContentScore_k^{(t)}, 0, 1)$ ，历史流使用显式衰减 Beta 更新：

$$a_k^{(t)} = \beta_h a_k^{(t-1)} + q_k^{(t)}, \quad b_k^{(t)} = \beta_h b_k^{(t-1)} + 1 - q_k^{(t)}, \quad HistPerf_k^{(t)} = \frac{a_k^{(t)}}{a_k^{(t)} + b_k^{(t)} + \varepsilon}. \quad (9)$$

新客户端从 $a_k^{(0)} = b_k^{(0)} = 1$ 开始，因此 $HistPerf_k^{(0)} = 0.5$ ；衰减因子 $\beta_h \in (0, 1)$ 在测试前固定。历史流会逐步降低权限，并允许合法长尾客户端恢复。风险流采用

$$RiskEMA_k^{(t)} = \beta_r RiskEMA_k^{(t-1)} + (1 - \beta_r) Risk_k^{inst}, \quad (10)$$

其中 $Risk_k^{inst}$ 为当轮最大探针，因此强警告不会被良性历史行为平均掉。

有效证明后的新客户端从 NORMAL 状态开始。令 $u_k^{(t)} = 1 - HistPerf_k^{(t)}$ 、 $r_k^{(t)} = RiskEMA_k^{(t)}$ ，阈值 $(\tau_h, \tau_s, \tau_q, \tau_b) = (0.26, 0.64, 0.80, 0.90)$ 分别表示效用缺口、软风险、隔离和黑名单。NORMAL 客户端在连续两轮满足 $u_k^{(t)} > \tau_h$ 或 $r_k^{(t)} \geq \tau_s$ 后进入 SUSPECT；SUSPECT 客户端在连续三轮满足相同条件，或某一轮当前探针满足 $Risk_k^{inst} \geq \tau_q$ 后进入 QUARANTINE；QUARANTINE 客户端在连续四轮满足 $r_k^{(t)} \geq \tau_b$ 后进入 BLACKLIST。SUSPECT 或 QUARANTINE 恢复需要连续两轮满足 $u_k^{(t)} \leq \tau_h$ 且 $r_k^{(t)} < \tau_s$ ；BLACKLIST 在一次实验内不可逆。条件不满足时计数器重置，状态更新在分层聚合前完成。首轮证据只能降低当前更新权限，不能触发永久黑名单。

这两个流只在计算聚合权限时汇合：

$$RawScore_k^{(t)} = (TrustScore_k^{(t)})^\alpha (ContentScore_k^{(t)})^\beta (HistPerf_k^{(t)})^\gamma \times (1 - RiskEMA_k^{(t)})^p. \quad (11)$$

因此，当轮风险可以否决高历史信誉的潜伏攻击，而低相似度的良性长尾客户端仍可通过慢速流恢复。

4.3 风险门控分层聚合

后门往往集中在深层，而浅层特征层可能携带有价值的异构信息。Trust Flow 因此为每个层 l 分配敏感度分数：定义三个归一化分量：

$$S_{priv}^{(l)} = \exp(-\tau_p l/L), \quad S_{util}^{(l)} = \frac{\|g_{root}^{(l)}\|_2}{\max_m \|g_{root}^{(m)}\|_2 + \varepsilon}, \quad (12)$$

$$S_{sec}^{(l)} = \frac{1}{2} \left(1 - \frac{1}{|\mathcal{T}|} \sum_{k \in \mathcal{T}} \cos(\Delta W_k^{(l)}, g_{root}^{(l)}) \right), \quad (13)$$

其中 $\mathcal{T} = \{k \in \mathcal{A} : M_{attest,k} = 1, RiskEMA_k^{(t-1)} < \tau_s\}$ 为可信参考集；若该集合为空，服务器仅使用 $\mathcal{A}$ 进行归一化并记录没有可信对等参考。因此 $S_{priv}^{(l)}$ 、 $1 - S_{util}^{(l)}$ 和 $S_{sec}^{(l)}$ 均位于 $[0, 1]$ 。取

$$S_{total}^{(l)} = w_p S_{priv}^{(l)} + w_u (1 - S_{util}^{(l)}) + w_s S_{sec}^{(l)}, \quad (w_p, w_u, w_s) = (0.3, 0.3, 0.4), \quad (14)$$

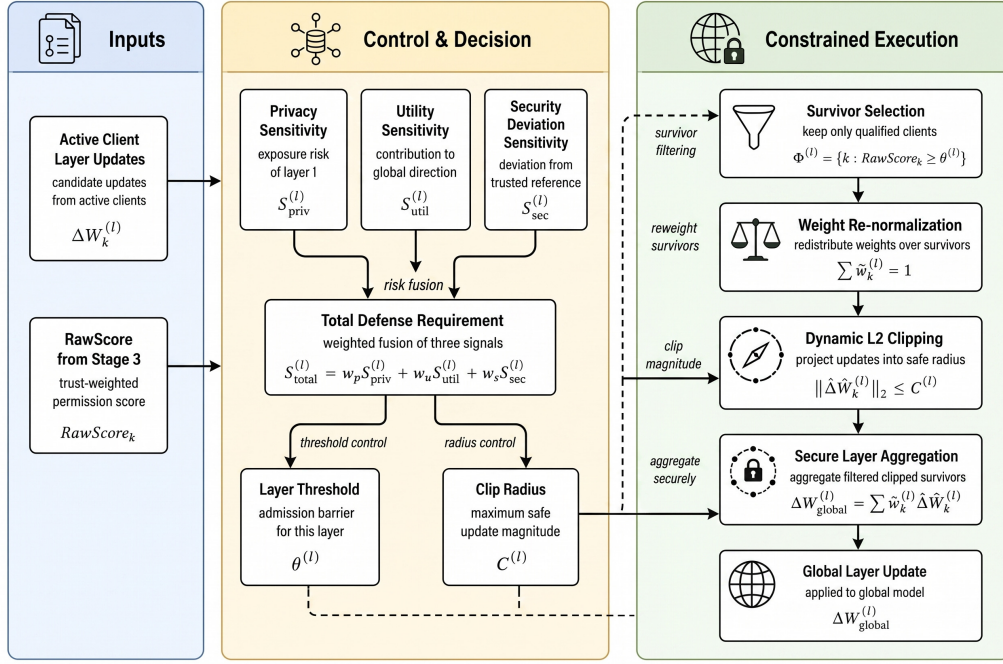


图 4: 风险门控的按层裁剪与差异化聚合。

并设置 $\theta^{(l)} = \mu_{base} + \lambda_s S_{total}^{(l)}$ 与 $C^{(l)} = C_{base} / (S_{total}^{(l)} + \varepsilon_c)$ 。若某层出现更强可疑漂移, 该层会变得更难进入且裁剪更紧; 若某层仍稳定接近参考方向, 则保留更多良性异构容量。

幸存者集合为 $\Phi^{(l)} = \{k \in \mathcal{A} \mid RawScore_k^{(t)} \geq \theta^{(l)}\}$, 并保留原始数据量权重 p_k , 其权重重新归一化为

$$\tilde{w}_k^{(l)} = \frac{p_k RawScore_k^{(t)}}{\sum_{j \in \Phi^{(l)}} p_j RawScore_j^{(t)} + \varepsilon}, \quad \widehat{\Delta W}_k^{(l)} = \frac{\Delta W_k^{(l)}}{\max(1, \|\Delta W_k^{(l)}\|_2 / C^{(l)})}. \quad (15)$$

最终更新为 $\Delta W_{global}^{(l)} = \sum_{k \in \Phi^{(l)}} \tilde{w}_k^{(l)} \widehat{\Delta W}_k^{(l)}$ 。若 $\Phi^{(l)} = \emptyset$, 则保留 $RawScore$ 最大的客户端并赋予单位归一化权重, 同时仍执行该层裁剪。权重重归一化可以防止剔除风险客户端后有效学习率缩小。

这种按层控制旨在保留有用的浅层表征, 同时加固攻击敏感度更高的层。以语义后门为例, 攻击通常更集中地改变最终分类层或深层特征层; 统一全局裁剪要么足够宽松以保留浅层特征, 要么足够严格以压制深层攻击, 却很难兼顾二者。Trust Flow 允许不同层在同一轮采用不同策略: 深层可以拒绝低权限客户端并收紧更新半径, 浅层在参考一致性稳定时仍可保持较宽松阈值。这种差异化处理很重要, 因为统一裁剪半径会过度压制良性特征提取层, 并在恶意客户端已被移出幸存集后拖慢收敛。

重归一化步骤对收敛同样关键。若没有该步骤, 剔除可疑客户端会降低有效聚合权重之和, 并形成隐式学习率衰减。这种衰减容易被误认为是鲁棒性控制带来的正常副作用, 但在固定 30 轮训练预算下会直接拖慢优化。Trust Flow 因此将过滤与优化视为耦合操作: 移除不安全权重后, 剩余可信权重会先被投影回有效聚合单纯形, 再进入裁剪和分层组装。

4.4 分析视角

双流结构为解释 FPR/ASR 权衡提供了一个简单视角。设合法长尾客户端的单轮内容服从期望为 μ_{clean} 、方差为 σ_{clean}^2 的扰动分布。刚性阈值会在当前分数低于阈值时剔除该客户端, 即便偏差来自 Non-IID 数据。经过指数平滑后, 历史效用估计的稳态方差遵循标准低通形式:

$$\text{Var}(HistPerf_k^{(\infty)}) = \frac{1 - \beta_h}{1 + \beta_h} \sigma_{clean}^2. \quad (16)$$

当 β_h 接近 1 时, 短期良性波动被抑制, 客户端更不容易遭到持续移除。相比之下, 瞬时风险流会响应攻击冲击。若某个后门轮次产生异常探针值, 最大算子会防止该事件在进入 EMA 前被平均掉。因此, 将长期贡献和短期风险放在不同空间处理, 可以减少单分数冲突: 长尾更新被平滑而非立即封禁, 突发恶意信号则保留足够强度以触发隔离。

表 1: 紧凑实验配置与主要超参数。

类别	设置	取值
FL 任务	数据集/模型/准入客户端	CIFAR-10/CIFAR-100 ResNet-18/ $K = 20$
优化	本地 epoch、学习率、动量、轮次	3, 0.001, 0.9, 30
数据异构	共享客户端池、服务器 proxy、Group A/B/C	5000、500、 $\alpha = 1.0, 0.1$
信任流	$\alpha_1, \alpha_2, \beta_{fusion}; \beta_h, \beta_r$	0.6, 0.4, 2.0; 0.9, 0.85
分层门控	融合指数; μ_{base}, λ_s	3.0, 1.0, 0.5, 1.0; 0.4, 1.2

4.5 风险探针计算

瞬时风险流使用的探针彼此冗余，而不是各自单独作出最终裁决。梯度探针同时度量相对 g_{root} 的方向偏离和相对本轮统计量的异常幅度，因此适合捕获符号翻转和梯度缩放，但对梯度方向接近良性的干净标签攻击并不充分。干净探针会将候选更新应用到服务器侧小型探针集，并记录交叉熵损失的上升。触发器探针通过 KL 散度比较高层激活直方图， $r_{trigger,k}^{(t)} = \text{KL}(\mathcal{H}(A_{base}) \parallel \mathcal{H}(A_k))$ ，因而更敏感于语义后门或干净标签后门造成的特征层漂移。

这些探针通过最大值规则融合，是因为它们的失效模式不同。高幅度攻击者通常会被梯度通道暴露，而隐蔽后门可能只表现为较小的干净损失变化，却伴随明显激活偏移。风险流保留本轮最强警告，使不同攻击家族都能被状态机看到，而不需要依赖一个统一的异常分数。

这些探针在审查中还具有诊断作用。若梯度通道占主导，服务器会将该客户端视为优化层面的威胁，并主要通过裁剪和层阈值抑制其影响；若干净探针或触发器通道占主导，则该更新在数值上可能看似普通，但语义上并不安全，因此即使历史效用较高，状态机也会推动该客户端进入隔离观察。群体分歧只作为辅助证据，而不是单独移除的理由，因为合法长尾客户端也可能与多数方向不一致。这种诊断分离降低了防御对单一分数校准的依赖，也解释了为何同一管线能够同时处理显式参数攻击、干净标签漂移和语义后门。

5 实验

5.1 实验设置

实验使用 Flower 1.5.0 与 PyTorch，在 CIFAR-10 上训练适配后的 ResNet-18：首层卷积为 3×3 、步长为 1，移除初始最大池化层，分类器输出 10 类。训练和可信执行在两个基于 Intel 与 AMD、支持 TEE 的真实平台上完成；NVIDIA A10 GPU 执行模型训练，CPU 侧 TEE 隔离证明、可信监测、报告生成和准入状态处理。软件栈为 Ubuntu 20.04.6 LTS 与 CUDA 12.8。50,000 张训练图像划分为一个对所有客户端复用的 5,000 张共享客户端池和 45,000 张专属图像：客户端 0–9 使用 IID 划分，客户端 10–14 使用 Dirichlet $\alpha = 1.0$ ，客户端 15–19 使用 $\alpha = 0.1$ 的强长尾划分。服务器另行持有来自 CIFAR-10 测试集的 500 张均衡 proxy 样本（每类 50 张），该集合不参与客户端训练，并向所有依赖参考集的基线提供。

正式 30% 攻击设置包含六个恶意客户端：Client 0 执行 $\gamma = 0.5$ 的无目标标签翻转；Client 1 在 20% 样本中注入固定右下角 3×3 触发器并以类别 0 为目标；Client 2 在 20% 样本上执行保持标签的干净标签扰动并使用相同目标；Client 3 在 20% 样本上施加固定语义属性偏置并将偏置子集分配到类别 0；Client 4 执行无目标符号翻转；Client 5 将更新放大 100 倍。六类行为在每轮本地训练中同时激活。另有五个无有效证书的 Sybil 节点和三个伪造低工作负载的 free-rider 节点仅用于验证第一阶段门控，并在统计聚合前被拦截，因此后续指标均在 20 个准入客户端上计算。每次运行包含 30 轮和 3 个本地 epoch。聚合值在两个平台各 5 个种子的 10 个平台-种子运行上计算，节点状态轨迹使用每个平台一个固定种子。

每个平台运行 5 个独立种子，准确率和 ASR 的均值与标准差在 10 个平台-种子运行上计算。永久封禁 FPR 以被不可逆列入黑名单的良性客户端计算，临时 SUSPECT 或 QUARANTINE 状态被视为可恢复控制动作。节点轨迹图使用每个平台一个固定种子，聚合表格使用重复运行结果。所有基线采用相同节点划分、攻击比例、优化器配置、通信轮次、参考集访问权限和 Non-IID 划分。

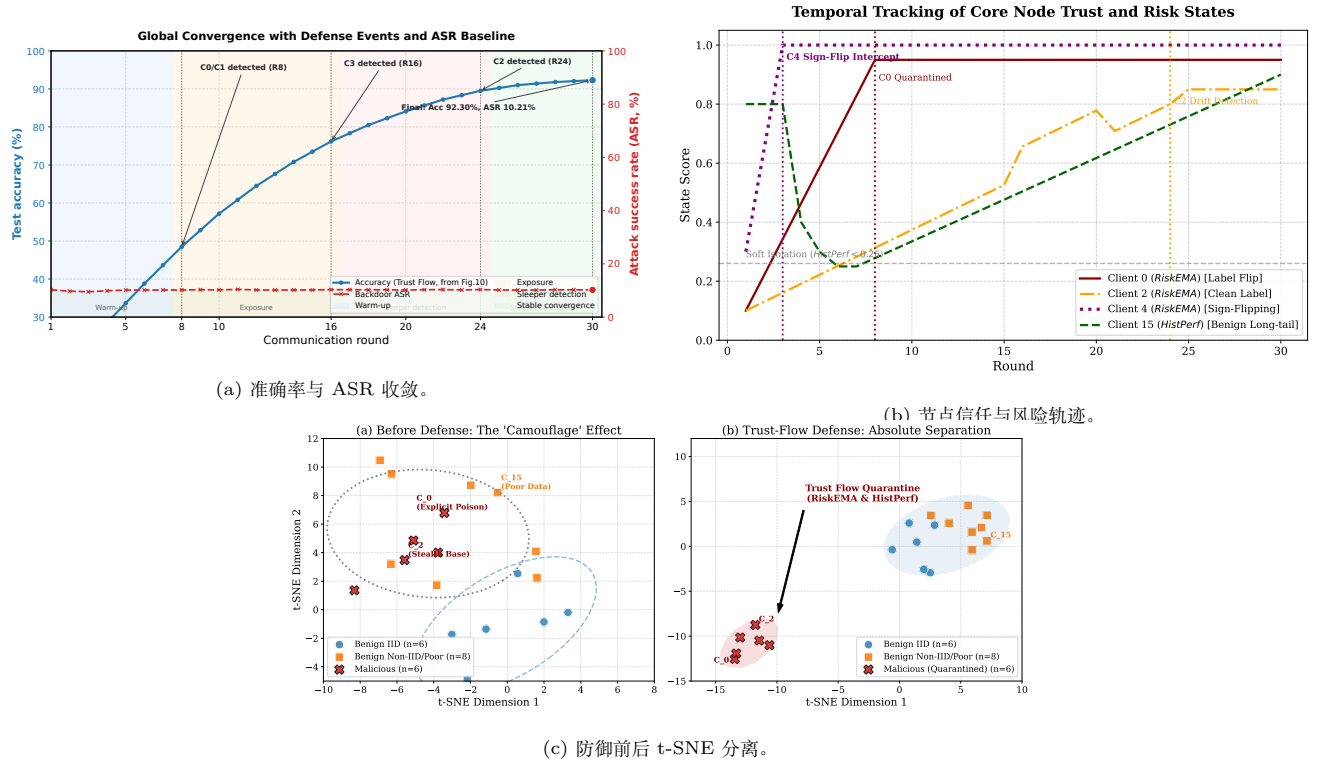


图 5: 混合攻击下的主要防御行为。

表 2: 30% 混合攻击与边界压力测试下的性能比较。

方法/设置	核心机制	Acc.	ASR	Perm. FPR
FedAvg [2]	无防御	86.15 $\pm$ 1.20	92.34 $\pm$ 5.10	N/A
Krum [3]	欧氏选择	64.20 $\pm$ 2.80	12.15 $\pm$ 0.90	N/A
Trimmed Mean [4]	坐标截断	71.35 $\pm$ 2.40	38.60 $\pm$ 4.20	N/A
FLTrust [5]	干净锚点加权	81.25 $\pm$ 1.50	15.42 $\pm$ 1.10	N/A
Trust Flow	双流 + 分层门控	92.31 $\pm$ 0.09	10.21 $\pm$ 0.05	0.00
边界压力: 50% 恶意	10/20 恶意	91.81 $\pm$ 0.10	10.46 $\pm$ 0.06	0.00

FPR 表示良性客户端的不可逆误封。临时 SUSPECT/QUARANTINE 状态是可恢复控制动作，并通过轨迹单独呈现。

5.2 整体防御性能

图 5 总结了收敛、ASR、信任状态轨迹和特征分离结果。在 30% 混合攻击下，Trust Flow 收敛到 92.31% 准确率，并将 ASR 降至 10.21%，接近 CIFAR-10 的随机猜测基线。客户端状态追踪显示，显式投毒与参数攻击会被早期阻断，而更隐蔽的干净标签漂移则在持续探针证据出现后被捕获。合法长尾节点可能暂时进入 SUSPECT 或 QUARANTINE，但其风险流不会积累足够证据导致永久封禁。上述观察仅适用于给定测试协议。

节点轨迹揭示了不同决策路径。标签翻转、触发器后门、语义后门和参数攻击会通过方向、幅度、干净损失、激活或群体探针逐步积累风险，并按照持久性规则进入隔离或黑名单。干净标签攻击更难检测，因为其本地损失可能保持正常；它需要持续的探针证据才能触发状态升级。相比之下，长尾良性客户端早期可能内容质量偏低，但风险流并不持续上升，因此可通过后续 *HistPerf* 更新恢复。该轨迹图来自固定种子，不代表普适的检测时间。

t-SNE 可视化提供了补充视角。信任流介入前，恶意客户端和合法长尾客户端可能处在重叠区域，因为二者都可能偏离多数方向。双流监督后，恶意客户端形成与高风险探针相关的可分离簇，而合法长尾客户端仍与主要聚合区域保持连接。这支持了本文的设计主张：历史效用和瞬时风险不应过早压缩为一个分数。

在匹配的经典基线比较中，Krum、Trimmed Mean 与 FLTrust 以一定准确率代价降低了 ASR，Trust Flow 在相同协议下取得 92.31% 的准确率和 10.21% 的目标 ASR 宏平均值。上述结果仅描述本实验协议下的重复运行汇总，不构成普适性排序；DeepSight、FLAME、CrowdGuard、RoseAgg、FLPurifier、ShieldFL 与 RaSA 等近期方法需要本文未复现的攻击或隐私接口，因此未纳入直接比较。50% 结果属于超出假设范围的压力测试，不能据此推导 Byzantine 理论边界。

表 3: 消融与开销概要。

研究项	变体/架构	FPR 或开销	TPR / 时间
信誉	单流 EMA, 激进	18.25% FPR	95.12% TPR
信誉	单流 EMA, 保守	2.10% FPR	48.33% TPR
信誉	HistPerf-only	0.15% FPR	21.05% TPR
信誉	双流 Trust Flow	0.00% FPR	100.00% TPR
开销	标准 FedAvg	额外 0 KB	2.10 s 聚合
开销	Trust Flow	~15 KB TrustReport	4.85 s 含审查

5.3 消融、敏感性与开销

表 3 表明, 单流信誉模型面临 FPR/TPR 权衡: 激进阈值增加误封, 保守阈值漏检潜伏攻击。仅使用 HistPerf 可以保护良性节点, 却缺少短期攻击敏感性。双流设计在保持永久误封较低的同时获得较高召回。TrustReport 每次上传约增加 15 KB, 服务器聚合与审查时间从每轮 2.10 s 增至 4.85 s; 该服务器侧测量不包含端到端通信和厂商特定证明延迟, enclave 切换、内存压力和密码学聚合路径另行实测为每个准入客户端每轮约 11 ms。密码学 secure aggregation 不在本文系统边界内。

辅助安全路径实测结果表明, 每个准入客户端每轮的 enclave 切换、内存压力和密码学聚合路径额外开销约为 11 ms; 设备侧 TEE Quote 生成、签名和轻量监测另行实测为每个准入客户端每轮约 12–15 ms。上述辅助路径与服务器侧主要结果分开报告, 因为主协议仍需检查单个客户端的证据。

表 3 中 FPR/TPR 采用最终封禁口径。若将 SUSPECT 计为可逆风险复核状态, 则恶意客户端逐轮覆盖率为 88.33%, 正常客户端复核触发率为 14.79%, 且不构成永久误杀。

图 6 和图 7 进一步分解了风险探针、权重重归一化和数据异构性的影响。干净参考结合浅层探针能够处理符号翻转和梯度缩放, 但在梯度方向与良性更新共线时, 干净标签后门仍较难识别。加入交叉熵与高层激活探针后, 干净标签 ASR 降至 9.2% 以下。重归一化同样重要: 没有幸存者权重修正的分层门控会产生隐式学习率衰减, 而完整 Trust Flow 能在 30 轮预算内收敛。在 Dirichlet $\alpha = 0.1$ 下, Krum 与 FLTrust 明显退化, 而 Trust Flow 仍保持接近 92% 的准确率。

Dirichlet 扫描属于同一家族分布偏移测试: 标签空间、模型、优化器和攻击协议保持不变, 仅将浓度参数从弱异构调整到强异构。随着 α 降低, Krum 与 FLTrust 越来越容易排除合法漂移; Trust Flow 在所报告的扫描范围内对该变化较不敏感, 因为内容证据与历史效用和瞬时风险共同整合。该结果是经验观察, 不构成分布无关保证。融合参数 β_{fusion} 控制干净参考支配群体一致性的强度, 默认 $\beta_{fusion} = 2.0$ 在观察结果中取得最好的 Acc/ASR 平衡。

开销分析将服务器侧 Trust Flow 处理与端到端部署成本分开。边缘侧附加约 15 KB 的 TrustReport; 服务器执行参考构建、成对一致性审查、双流更新和按层裁剪, 使聚合与审查时间从测试环境中的 2.10 s 增至 4.85 s。该测量报告的是服务器侧协议开销结果; 辅助安全路径实测为每个准入客户端每轮约 11 ms, 设备侧 TEE Quote 生成、签名和轻量监测另行实测为每个准入客户端每轮约 12–15 ms, 端到端部署是否可接受仍取决于本文未测量的通信和厂商特定证明特性。

6 讨论与结论

Trust Flow 将准入证据、内容审查、时序信誉和按层聚合整合为一条统一的信任状态管线。其主要收益不仅是更强的攻击抑制, 还在于更清晰地区分两类低更新相似性的来源: 良性长尾数据和恶意操纵。这一区分使方法能够在混合攻击下保持较高召回, 同时让永久封禁 FPR 在测试运行中保持为零。

本文仍存在若干局限。纯净参考集和激活探针依赖明确声明的服务器侧 proxy 集, peer-reference 分支虽已定义但未用于标题结果; 由于多种新兴 TEE-FL、时序、后门和隐私保护方法尚无可复现接口, 本文只报告匹配的经典基线。当前探针设计主要针对视觉分类, 完整端到端证明、通信延迟和厂商特定组件仍未测量; 设备侧 TEE Quote 生成、签名和轻量监测已单独实测为每个准入客户端每轮约 12–15 ms, enclave 切换、内存压力和密码学聚合路径已作为辅助安全路径单独实测。后续工作将评估无参考设置、匹配的现代基线、更大规模边缘部署及非视觉联邦任务。

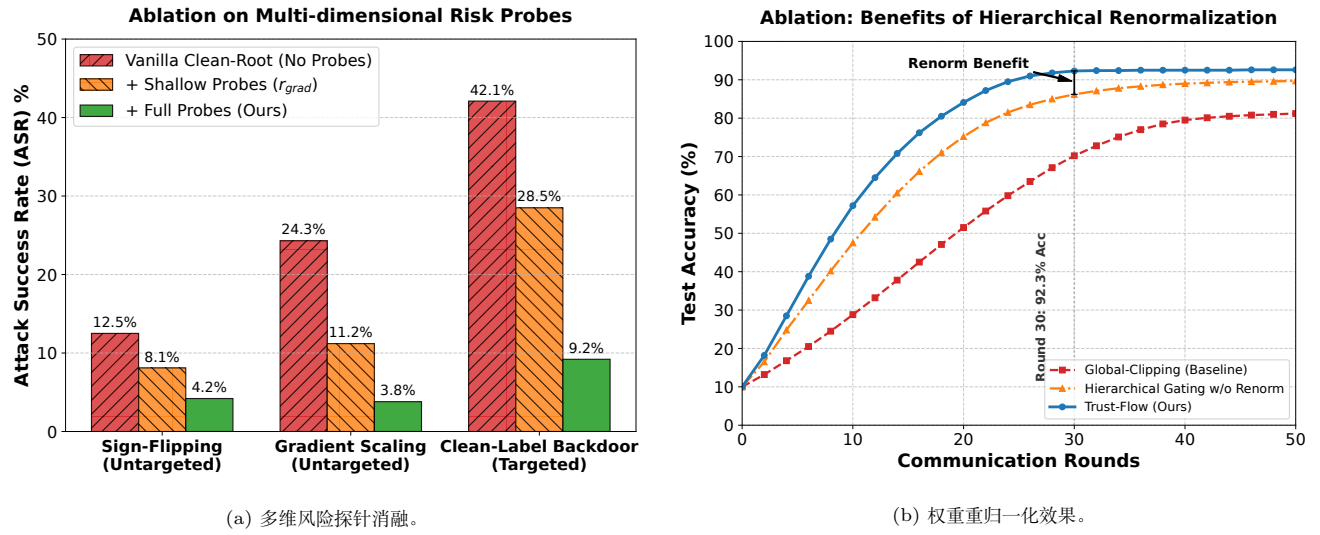


图 6: 风险探针与重归一化的组件级消融。

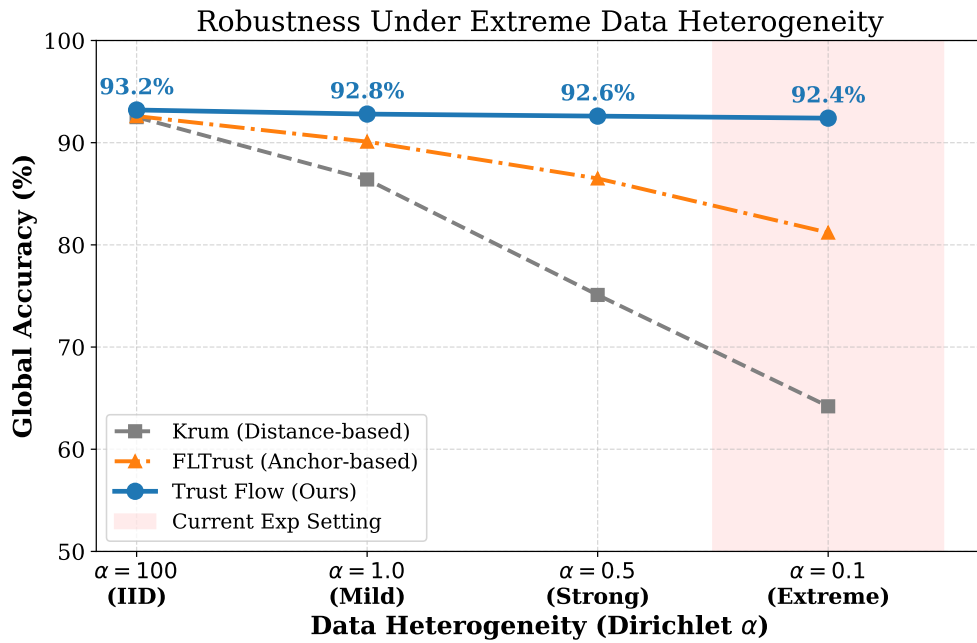


图 7: 不同数据异构度下的鲁棒性压力测试。

致谢

本研究得到国家自然科学基金项目 (No. 62002261) 和天津市自然科学基金项目 (No. 25JCQNJC00600) 的支持。

参考文献

- [1] Kairouz, P., McMahan, H.B., Avent, B., et al.: Advances and open problems in federated learning. Foundations and Trends in Machine Learning 14(1–2), 1–210 (2021). <https://doi.org/10.1561/22000000083>
- [2] McMahan, B., Moore, E., Ramage, D., Hampson, S., Aguera y Arcas, B.: Communication-efficient learning of deep networks from decentralized data. In: Proceedings of the 20th International Conference on Artificial Intelligence and Statistics, PMLR 54, pp. 1273–1282 (2017). <https://proceedings.mlr.press/v54/mcmahan17a.html>
- [3] Blanchard, P., El Mhamdi, E.M., Guerraoui, R., Stainer, J.: Machine learning with adversaries: Byzantine tolerant gradient descent. In: Advances in Neural Information Processing Systems 30 (2017). [NeurIPS paper page](#)
- [4] Yin, D., Chen, Y., Ramchandran, K., Bartlett, P.: Byzantine-robust distributed learning: Towards optimal statistical rates. In: Proceedings of the 35th International Conference on Machine Learning, PMLR 80, pp. 5650–5659 (2018).

<https://proceedings.mlr.press/v80/yin18a.html>

- [5] Cao, X., Fang, M., Liu, J., Gong, N.Z.: FLTrust: Byzantine-robust federated learning via trust bootstrapping. In: Proceedings 2021 Network and Distributed System Security Symposium (NDSS) (2021). <https://doi.org/10.14722/ndss.2021.24434>
- [6] Fung, C., Yoon, C.J.M., Beschastnikh, I.: The limitations of federated learning in Sybil settings. In: 23rd International Symposium on Research in Attacks, Intrusions and Defenses (RAID 2020), pp. 301–316. USENIX Association (2020). <https://www.usenix.org/conference/raid2020/presentation/fung>
- [7] Wang, L., Huang, M., Zhang, Z., Li, M., Wang, J., Gai, K.: RaSA: Robust and adaptive secure aggregation for edge-assisted hierarchical federated learning. IEEE Transactions on Information Forensics and Security 20, 4280–4295 (2025). <https://doi.org/10.1109/TIFS.2025.3559411>
- [8] Zhang, Z., Cao, X., Jia, J., Gong, N.Z.: FLDetector: Defending federated learning against model poisoning attacks via detecting malicious clients. In: Proceedings of the 28th ACM SIGKDD Conference on Knowledge Discovery and Data Mining, pp. 2545–2555 (2022). <https://doi.org/10.1145/3534678.3539231>
- [9] Rieger, P., Nguyen, T.D., Miettinen, M., Sadeghi, A.R.: DeepSight: Mitigating backdoor attacks in federated learning through deep model inspection. In: Network and Distributed System Security Symposium (NDSS) (2022). <https://doi.org/10.14722/ndss.2022.23156>
- [10] Nguyen, T.D., Rieger, P., Chen, H., et al.: FLAME: Taming backdoors in federated learning. In: 31st USENIX Security Symposium, pp. 1415–1432 (2022). <https://www.usenix.org/conference/usenixsecurity22/presentation/nguyen>
- [11] Rieger, P., Krauß, T., Miettinen, M., Dmitrienko, A., Sadeghi, A.R.: CrowdGuard: Federated backdoor detection in federated learning. In: Network and Distributed System Security Symposium (NDSS) (2024). <https://doi.org/10.14722/ndss.2024.23233>
- [12] Zhang, J., Zhu, C., Sun, X., Ge, C., Chen, B., Susilo, W., Yu, S.: FLPurifier: Backdoor defense in federated learning via decoupled contrastive training. IEEE Transactions on Information Forensics and Security 19, 4752–4766 (2024). <https://doi.org/10.1109/TIFS.2024.3384846>
- [13] Yang, H., Xi, W., Shen, Y., Wu, C., Zhao, J.: RoseAgg: Robust defense against targeted collusion attacks in federated learning. IEEE Transactions on Information Forensics and Security 19, 2951–2966 (2024). <https://doi.org/10.1109/TIFS.2024.3352415>
- [14] Ma, Z., Ma, J., Miao, Y., Li, Y., Deng, R.H.: ShieldFL: Mitigating model poisoning attacks in privacy-preserving federated learning. IEEE Transactions on Information Forensics and Security 17, 1639–1654 (2022). <https://doi.org/10.1109/TIFS.2022.3169918>
- [15] Zhang, X., Chen, Z., Chen, G., Feng, X., Shen, Q., Wu, Z.: RPPFL: Robust and privacy-preserving federated learning via trusted execution environments. In: ICASSP 2025 - 2025 IEEE International Conference on Acoustics, Speech and Signal Processing, pp. 1–5 (2025). <https://doi.org/10.1109/ICASSP49660.2025.10889398>
- [16] Chen, Y., Luo, F., Li, T., Xiang, T., Liu, Z., Li, J.: A training-integrity privacy-preserving federated learning scheme with trusted execution environment. Information Sciences 522, 69–79 (2020). <https://doi.org/10.1016/j.ins.2020.02.037>
- [17] Queyrut, S., Schiavoni, V., Felber, P.: Mitigating adversarial attacks in federated learning with trusted execution environments. In: 2023 IEEE 43rd International Conference on Distributed Computing Systems (ICDCS), pp. 626–637 (2023). <https://doi.org/10.1109/ICDCS57875.2023.00069>
- [18] Xu, T., Zhu, K., Andrzejak, A., Zhang, L.: Distributed learning in trusted execution environment: A case study of federated learning in SGX. In: 2021 7th IEEE International Conference on Network Intelligence and Digital Content (IC-NIDC), pp. 450–454 (2021). <https://doi.org/10.1109/IC-NIDC54101.2021.9660433>
- [19] Lu, Z., Wang, L., Zhang, Z., Huang, M., Wang, J., Li, M.: TMT-FL: Enabling trustworthy model training of federated learning with malicious participants. IEEE Transactions on Dependable and Secure Computing 22(3), 2723–2740 (2025). <https://doi.org/10.1109/TDSC.2024.3521377>
- [20] Bagdasaryan, E., Veit, A., Hua, Y., Estrin, D., Shmatikov, V.: How To Backdoor Federated Learning. In: Proceedings of the Twenty Third International Conference on Artificial Intelligence and Statistics, PMLR 108, pp. 2938–2948 (2020). <https://proceedings.mlr.press/v108/bagdasaryan20a.html>

- [21] Wang, B., Yao, Y., Shan, S., Li, H., Viswanath, B., Zheng, H., Zhao, B.Y.: Neural Cleanse: Identifying and mitigating backdoor attacks in neural networks. In: 2019 IEEE Symposium on Security and Privacy (SP), pp. 707–723 (2019). <https://doi.org/10.1109/SP.2019.00031>